

MEDICONNECT HEALTH CYBER RISK ASSESSMENT

EXECUTIVE SUMMARY — JUNIOR GRC PORTFOLIO

Executive Summary professionale per management, basato su un cyber risk assessment di 15 rischi relativi a identità digitali, dati sanitari, cloud security, ransomware, fornitori terzi e incident response.

Prepared by	Fabio De Zanet
Role	Junior Cybersecurity Risk Analyst
Assessment Period	2026
Document Status	Draft
Version	1.0

INDICE DEI CONTENUTI

1. Executive Overview	3
2. Assessment Scope	4
3. Risk Methodology	5
4. Key Findings	6
5. Top Risks Identified	7
6. Management Recommendations	8
7. Conclusion	9
8. Portfolio Note	10

CYBER RISK ASSESSMENT — EXECUTIVE SUMMARY

1. Executive Overview

Questa valutazione ha identificato e analizzato 15 rischi di cybersecurity relativi a MediConnect Health S.r.l., una società fittizia europea operante nel settore della telemedicina.

L'azienda fornisce servizi digitali per consultazioni mediche online, prenotazione visite, gestione di referti, prescrizioni digitali, comunicazioni tra pazienti e professionisti sanitari e pagamenti online.

Poiché MediConnect Health tratta dati personali, dati sanitari, credenziali utente e informazioni di pagamento, la protezione della riservatezza, integrità e disponibilità dei sistemi è essenziale per garantire continuità del servizio, fiducia dei pazienti e conformità normativa.

2. Assessment Scope

Il perimetro dell'assessment include i rischi di cybersecurity relativi a:

- piattaforma web e mobile di telemedicina;
- infrastruttura cloud AWS;
- database dei dati sanitari dei pazienti;
- ambiente Microsoft 365;
- dispositivi dei dipendenti e dei professionisti sanitari;
- fornitori terzi critici;
- processi di access management, backup, logging e incident response.

Sono esclusi dal perimetro la sicurezza fisica, la responsabilità professionale sanitaria e i rischi finanziari generali, salvo quando tali rischi derivano direttamente da un incidente informatico.

3. Risk Methodology

I rischi sono stati valutati utilizzando una scala da 1 a 5 per:

Likelihood — probabilità che l'evento si verifichi.

Impact — gravità dell'impatto in caso di accadimento.

Il punteggio di rischio è stato calcolato con la formula:

$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$

La classificazione utilizzata è:

Risk Score	Rating
1–4	Low
5–9	Medium
10–15	High
16–25	Critical

Sono stati valutati sia il rischio inerente, cioè il rischio prima dei controlli, sia il rischio residuo, cioè il rischio che rimane dopo aver considerato i controlli attuali.

4. Key Findings

Finding ID	Key Finding
KF-01	I rischi più critici riguardano compromissione degli account, esposizione dei dati sanitari, cloud misconfiguration e ransomware.
KF-02	Il database dei dati sanitari dei pazienti è uno degli asset più critici per impatto privacy, operativo e reputazionale.
KF-03	L'assenza di MFA estesa a tutti gli utenti aumenta il rischio di accesso non autorizzato.
KF-04	La dipendenza da fornitori SaaS e cloud richiede un processo strutturato di vendor risk management.
KF-05	Il monitoraggio non centralizzato può ritardare la rilevazione di incidenti e aumentare il tempo di permanenza di un attaccante nei sistemi.
KF-06	Il processo Joiner-Mover-Leaver parzialmente manuale può lasciare account attivi non necessari.
KF-07	I controlli su backup, restore e incident response devono essere testati regolarmente per garantire resilienza operativa.

5. Top Risks Identificati

Rank	Risk ID	Risk Theme	Business Impact	Priority
1	R-01	Account compromise	Possibile accesso non autorizzato agli account dei pazienti e ai dati sanitari.	Critical
2	R-03	Cloud misconfiguration	Possibile esposizione pubblica di referti e dati sanitari.	Critical
3	R-05	Ransomware / Backup recovery	Possibile interruzione prolungata dei servizi di telemedicina.	Critical
4	R-09	Third-party risk	Possibile impatto su disponibilità del servizio e protezione dei dati causato da vendor critici.	High
5	R-12	Access management / JML	Possibile mantenimento di account non revocati e accessi non autorizzati.	High

6. Management Recommendations

Recommendation ID	Recommendation	Expected Benefit
REC-01	Estendere MFA a pazienti, dipendenti e professionisti sanitari.	Riduce il rischio di account compromise.
REC-02	Implementare SIEM e centralizzare i security logs.	Migliora detection, investigation e incident response.
REC-03	Introdurre CSPM per il monitoraggio delle configurazioni cloud AWS.	Riduce il rischio di cloud misconfiguration.
REC-04	Rafforzare il vendor risk management per fornitori SaaS e cloud critici.	Migliora il controllo sui rischi di terze parti.
REC-05	Implementare immutable backups e test periodici di restore.	Aumenta la resilienza contro ransomware e outage.
REC-06	Automatizzare il processo Joiner-Mover-Leaver.	Riduce il rischio di account orfani o accessi non autorizzati.
REC-07	Introdurre MDM per dispositivi dei professionisti sanitari e policy BYOD.	Riduce il rischio legato a endpoint non gestiti.
REC-08	Formalizzare e testare un incident response plan.	Riduce tempi di risposta, impatto reputazionale e rischio compliance.

7. Conclusione

La valutazione evidenzia che MediConnect Health presenta un'esposizione significativa ai rischi legati a identità digitali, dati sanitari, cloud security, ransomware, access management, fornitori terzi e incident response.

Le priorità di trattamento dovrebbero concentrarsi sull'estensione della MFA, sul miglioramento del monitoraggio tramite SIEM, sull'introduzione di controlli CSPM, sulla revisione periodica degli accessi, sul rafforzamento dei controlli sui fornitori e sul miglioramento delle capacità di backup e recovery.

L'implementazione delle raccomandazioni proposte ridurrebbe in modo significativo il rischio residuo e migliorerebbe la capacità dell'organizzazione di proteggere i dati sanitari dei pazienti, garantire continuità del servizio e mantenere conformità normativa.

8. Portfolio Note

Questo progetto dimostra competenze pratiche in:

- cybersecurity risk assessment;
- sviluppo di un risk register;
- valutazione di rischio inerente e residuo;
- identificazione di controlli attuali;
- definizione di treatment plan;
- comunicazione del rischio al management;
- documentazione GRC;
- analisi di rischi cloud, privacy, access management e third-party risk.